

Chapter 6 — Vulnerability, Exposure, and Patch Management

1. Document control

- Identifier: HAL-BVI-06
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Discover, validate, prioritize, remediate, disclose, and verify vulnerabilities and exposures without treating severity scores as sufficient risk judgment.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 26, 38, 42, 44
- Book II: Chapters 2, 28, 31-33
- Book III: Chapters 5, 7-9
- Book IV: CMP-24-26
- Book X: Chapters 7-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Vulnerability Program Owner, Asset Owner, Security Operations, Patch Authority, Risk Steward, Independent Assessor.

6. Normative controls

VI-VUL-06-001 — Maintain exposure-aware inventory

The vulnerability program **MUST** continuously map assets, versions, dependencies, internet and cross-domain exposure, identities, privileges, data classes, and authoritative responsibilities.

- Applicability: all assets
- Responsible role: Vulnerability Program Owner
- Enforcement: inventory reconciliation
- Required evidence: asset exposure inventory
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-VUL-06-002 — Accept findings from multiple channels

Automated scans, advisories, dependency intelligence, researcher reports, penetration tests, incidents, anomaly evidence, and internal review MUST enter one tracked disposition process.

- Applicability: all findings
- Responsible role: Vulnerability Program Owner
- Enforcement: intake workflow
- Required evidence: finding record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-VUL-06-003 — Prioritize by HAL consequence

Remediation priority MUST consider exploitability, exposure, privilege, authority path, data sensitivity, trust boundary, component ownership, containment, detectability, recovery, and credible harm—not severity score alone.

- Applicability: all findings
- Responsible role: Risk Steward
- Enforcement: risk scoring review
- Required evidence: prioritization rationale
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-VUL-06-004 — Meet risk-based remediation targets

Critical exploitable findings affecting authority, constitutional controls, protected state, external trust, or sensitive data MUST receive immediate containment and an approved remediation deadline.

- Applicability: critical findings
- Responsible role: Asset Owner
- Enforcement: SLA and containment gate
- Required evidence: containment and remediation evidence
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-VUL-06-005 — Test patches before adoption

Patches MUST undergo impact analysis, provenance validation, representative testing, rollback or forward-recovery preparation, and post-update verification proportional to urgency and consequence.

- Applicability: all patches
- Responsible role: Patch Authority
- Enforcement: change admission gate
- Required evidence: patch qualification record
- Severity: High
- Exception authority: Patch Authority
- Protection objective: Both

VI-VUL-06-006 — Do not remove critical checks for urgency

Emergency remediation MAY compress ordinary timing but MUST NOT bypass identity, Authority, constitutional invariants, provenance, evidence, or recovery controls.

- Applicability: emergency patches
- Responsible role: Patch Authority
- Enforcement: emergency change policy
- Required evidence: emergency patch record
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-VUL-06-007 — Verify closure

A finding closes only when the fix or compensating control is deployed to every in-scope asset, independently verified, monitored, and linked to residual risk; ticket closure alone is insufficient.

- Applicability: all remediations
- Responsible role: Independent Assessor
- Enforcement: retest and inventory reconciliation
- Required evidence: closure verification
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-VUL-06-008 — Coordinate disclosure safely

Disclosure MUST protect affected people, preserve evidence, respect authorized reporting channels and Treaties, avoid enabling preventable harm, and never conceal material risk from accountable decision-makers.

- Applicability: disclosures
- Responsible role: Security and Trust Executive
- Enforcement: disclosure review
- Required evidence: disclosure decision record
- Severity: High
- Exception authority: Owner only for genuine Owner matters
- Protection objective: Both

7. Required operating practices

Control Owners MUST maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 26, 38, 42, 44
- Book II: Chapters 2, 28, 31-33
- Book III: Chapters 5, 7-9
- Book IV: CMP-24-26
- Book X: Chapters 7-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a credential with favorable Trust evidence, passing scan, active certificate, or urgent incident as Permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.